

Praesentationen

Informatik · Klasse 10 · md

Inhaltsverzeichnis

Präsentation - Lernbereich 1: Webbasierte Anwendungen	2
Zweck und Einsatz	2
Prinzip für die Lehrerhinweise	2
Folie 1 – Einstieg: Wo läuft eine Webanwendung?	2
Folie 2 – Was gehört zur Webanwendung?	2
Folie 3 – Das 3-Tier-Modell	2
Folie 4 – Client/Server ist nicht dasselbe wie 3-Tier	3
Folie 5 – Clientseitige Webanwendung: Angular-SPA	3
Folie 6 – Serverseitiges Rendering: Beispiel PHP	3
Folie 7 – Moderne Anwendungen sind oft Mischformen	3
Folie 8 – HTTP: Request und Response	3
Folie 9 – Kommunikation ist nicht immer nur Request/Response	4
Folie 10 – Hypertext und HTML	4
Folie 11 – Webseite als strukturierte Elemente	4
Folie 12 – Wo steht der Server?	4
Folie 13 – Was bedeutet Cloud?	5
Folie 14 – SaaS, PaaS und IaaS	5
Folie 15 – Shared Responsibility	5
Folie 16 – Unsere Anwendung funktioniert. Ist sie damit gut?	5
Folie 17 – IT-Security und CIA	6
Folie 18 – Angriffsfläche	6
Folie 19 – White Hat, Black Hat, Grey Hat	6
Folie 20 – Penetration Testing	6
Folie 21 – Security by Design	6
Folie 22 – Authentifizierung und Autorisierung	7
Folie 23 – Kontoschutz und MFA	7
Folie 24 – Social Engineering	7
Folie 25 – Phishing	7
Folie 26 – Backup und Wiederherstellung	8
Folie 27 – Backup ist selbst ein Security- und Datenschutzthema	8
Folie 28 – Wofür Verschlüsselung?	8
Folie 29 – HTTPS/TLS: Schutz der Kommunikation	8
Folie 30 – Verschlüsselung gespeicherter Daten	9
Folie 31 – Symmetrisch und asymmetrisch	9
Folie 32 – Verschlüsselung, Hashing, Signatur	9
Folie 33 – IT-Sicherheit ≠ Datenschutz	9
Folie 34 – DSGVO	10
Folie 35 – NIS2: Cybersicherheit als Organisationsaufgabe	10
Folie 36 – KI auf Angreifer- und Verteidigerseite	10
Folie 37 – KI-generierter Code: niemals blind übernehmen	10
Folie 38 – Abschlussfall Schülerfestival	11
Folie 39 – Sicherung	11
Folie 40 – Exit-Ticket	11
Konventionen für Präsentation und Lehrerhinweise - Klasse 10 Webbasierte Anwendungen	12
Fachbegriffe und Abkürzungen	12
Lehrerhinweise	12
3-Tier und Schichten	12
Client/Server, Frontend/Backend und Rendering	12
Kommunikation	13

Präsentation - Lernbereich 1: Webbasierte Anwendungen

Zweck und Einsatz

Diese Datei ist die inhaltliche Masterquelle für die PowerPoint-Präsentation. Die Präsentation begleitet mehrere Unterrichtsstunden und ist **nicht** als Vortrag aller Folien in einer Einzelstunde gedacht.

Roter Faden: **Webanwendung als Gesamtsystem → Architektur → Kommunikation → Cloud → Verantwortung → IT-Security → Datenschutz → KI → verantwortungsvoller Betrieb.**

Durchgängiges Beispiel ist eine Webanwendung für ein **Schülerfestival**: Schülerinnen und Schüler melden sich an, wählen Workshops und erhalten einen persönlichen Zeitplan.

Prinzip für die Lehrerhinweise

Die Präsentation setzt bei Lehrkräften keine berufspraktische Erfahrung mit Webentwicklung, Cloud oder IT-Security voraus. Fachbegriffe werden bei der ersten Verwendung erklärt. Die Lehrerhinweise enthalten Hintergrundwissen, typische Fehlvorstellungen und Grenzen vereinfachter Modelle. Schüler müssen nicht alle Vertiefungsbegriffe auswendig lernen.

Folie 1 - Einstieg: Wo läuft eine Webanwendung?

Leitfrage: Du öffnest eine Webanwendung im Browser. Wo läuft sie eigentlich?

Mögliche Antworten sammeln: Browser, eigener Rechner, Server, Rechenzentrum, Cloud.

Lehrerhinweis: Mehrere Antworten können gleichzeitig richtig sein. Eine Webanwendung kann Code auf dem Client und auf Servern ausführen. „Webanwendung“ beschreibt daher nicht einfach „ein Programm auf einem Server“.

Folie 2 - Was gehört zur Webanwendung?

Schülerfestival: anmelden → Workshops ansehen → wählen → Zeitplan erhalten.

Nach Klick: Benutzeroberfläche · Programmlogik · Daten · Benutzer-/Rechteverwaltung · Netzwerkkommunikation · ggf. externe Dienste.

Merksatz: Eine Webanwendung ist ein Anwendungssystem – nicht nur die sichtbare Webseite.

Lehrerhinweis: Frontend bezeichnet den benutzernahen Teil, Backend servernahe Dienste und Anwendungslogik. Datenhaltung kann Datenbanken, Dateien oder Objektspeicher umfassen. Reale Systeme können weitere Dienste enthalten.

Folie 3 - Das 3-Tier-Modell

Presentation Tier → Application Tier → Data Tier
Benutzerschnittstelle Anwendungslogik Datenhaltung

Lehrerhinweis: Ein *Tier* ist hier eine Architektur-/Bereitstellungsebene. Drei Tiers bedeuten nicht zwingend drei physische Rechner. Mehrere Tiers können auf einem System laufen; ein Tier kann auf viele Systeme verteilt sein. Das Modell hilft, Verantwortlichkeiten zu trennen.

Folie 4 - Client/Server ist nicht dasselbe wie 3-Tier

Client/Server: Wer fordert einen Dienst an und wer stellt ihn bereit?

3-Tier: Wie sind Verantwortlichkeiten der Anwendung strukturiert?

Lehrerhinweis: „Frontend = Client“ und „Backend = Server“ ist als Einstieg nützlich, aber nicht allgemeingültig. Auch Teile der Darstellung können serverseitig entstehen.

Folie 5 - Clientseitige Webanwendung: Angular-SPA

Webserver liefert HTML/CSS/JavaScript → Browser führt Frontend-Code aus → API → Backend → Datenhaltung.

Lehrerhinweis: SPA = *Single Page Application*. Angular ist nur ein Beispiel. Die Anwendung wird gehostet und ausgeliefert; danach läuft ein großer Teil des Frontends lokal im Browser. Das Backend bleibt trotzdem Teil der Webanwendung.

Folie 6 - Serverseitiges Rendering: Beispiel PHP

Browser → Anfrage → Webserver/PHP → Logik/Datenzugriff → erzeugtes HTML → Browser.

Lehrerhinweis: Beim serverseitigen Rendering erzeugt der Server HTML für die Antwort. JavaScript kann zusätzlich im Browser laufen. PHP ist ein anschauliches Beispiel, nicht die einzige Technologie.

Folie 7 - Moderne Anwendungen sind oft Mischformen

Leitfrage: Wer erledigt welche Arbeit – und warum?

Kriterien: Datenzugriff · Sicherheit · Reaktionsgeschwindigkeit · Rechenaufwand · Offline-Fähigkeit · Wartbarkeit.

Lehrerhinweis: Moderne Frameworks kombinieren häufig client- und serverseitige Verarbeitung. Die Folie soll bewusst eine Schwarz-Weiß-Einteilung verhindern.

Folie 8 - HTTP: Request und Response

Client --Request--> Server

Client <--Response-- Server

Begriffe: HTTP/HTTPS · Request · Response · API.

Lehrerhinweis: HTTP ist ein Anwendungsprotokoll für den Austausch von Nachrichten. Eine API (*Application Programming Interface*) ist eine definierte Schnittstelle, über die Softwarefunktionen bzw. Daten angeboten werden. HTTPS bedeutet HTTP über TLS. Es schützt insbesondere die Übertragung und authentisiert die Gegenstelle über Zertifikate; es garantiert nicht, dass Inhalt oder Anwendung vertrauenswürdig sind.

Folie 9 - Kommunikation ist nicht immer nur Request/Response

Leitfrage: Was passiert, wenn der Server dem Browser sofort mitteilen soll, dass sich ein Workshopraum geändert hat?

Vergleich:

Modell	Grundidee	Typischer Einsatz
HTTP Request/Response	Client fragt, Server antwortet	API, Seite laden
Polling	Client fragt regelmäßig nach	einfacher Statuscheck
Server-Sent Events (SSE)	länger offene Verbindung, Server sendet Ereignisse zum Client	Live-Feed
WebSocket	dauerhafte bidirektionale Verbindung	Chat, Kollaboration, Live-Updates

Lehrerhinweis: Bei WebSocket baut der Client zunächst eine Verbindung auf. Danach können **beide Seiten** Nachrichten senden. Ein fachliches „Registrieren auf Events“ bzw. Subscription-Modell kann die Anwendung darüber implementieren, ist aber nicht durch WebSocket selbst vorgeschrieben. *Polling* bedeutet wiederholtes Nachfragen. *SSE* ermöglicht primär Server→Client-Ereignisse über eine länger offene HTTP-Verbindung. Client/Server beschreibt Rollen, nicht die Richtung jeder einzelnen Nachricht.

Folie 10 - Hypertext und HTML

Internet ≠ World Wide Web. Das Web nutzt u. a. URLs, HTTP(S) und Hypertext auf der Internet-Infrastruktur.

```
<h1>Schülerfestival</h1>
<p>Programm am Freitag</p>
<a href="programm.html">Zum Programm</a>
```

Lehrerhinweis: HTML (*HyperText Markup Language*) ist eine Auszeichnungssprache, keine Programmiersprache im engeren Sinn. Hypertext verbindet Dokumente/Ressourcen durch Verweise.

Folie 11 - Webseite als strukturierte Elemente

Überschrift · Link · Bild · Formularfeld; Elemente besitzen Attribute/Eigenschaften.

Lehrerhinweis: Die Analogie zu Objekten dient nur der Strukturbetrachtung. HTML-Elemente sind nicht automatisch Domänenobjekte einer objektorientierten Anwendung.

Folie 12 - Wo steht der Server?

Eigener Server · Rechenzentrum · Hosting-Anbieter · Cloud-Infrastruktur.

Frage: Ist Cloud eine Anwendungsarchitektur wie 3-Tier? → **Nein.**

Lehrerhinweis: 3-Tier beschreibt eine Struktur der Anwendung; Cloud beschreibt eine Form der Bereitstellung/Nutzung von IT-Ressourcen und Diensten. Beides kann kombiniert werden.

Folie 13 - Was bedeutet Cloud?

Cloud = reale Rechenleistung, Speicher, Netzwerk und Dienste in Rechenzentren, die über Netze flexibel bereitgestellt werden.

Lehrerhinweis: „Cloud“ bedeutet nicht, dass Daten ortlos sind. Physische Systeme stehen in Rechenzentren. Für Datenschutz, Verfügbarkeit und Abhängigkeiten können Betreiber, Standort/Region, Vertrag und Dienstmodell relevant sein.

Folie 14 - SaaS, PaaS und IaaS

SaaS - Software as a Service: fertige Anwendung als Dienst nutzen.

PaaS - Platform as a Service: eigene Anwendung auf einer bereitgestellten Plattform/Laufzeit betreiben.

IaaS - Infrastructure as a Service: virtualisierte Rechen-, Speicher- und Netzwerkressourcen nutzen und darauf mehr selbst betreiben.

Lehrerwissen - SaaS: Der Anbieter betreibt typischerweise Anwendung, Plattform und Infrastruktur. Der Kunde nutzt und konfiguriert die Anwendung und bleibt u. a. für Benutzer, Berechtigungen, Daten und passende Konfiguration verantwortlich. SaaS bedeutet **Software as a Service**, nicht „Service as a Service“.

Lehrerwissen - PaaS: Der Anbieter stellt eine Laufzeit-/Entwicklungsplattform bereit. Entwickler deployen ihren eigenen Anwendungscode, ohne jeden Server und jedes Betriebssystem selbst administrieren zu müssen. Beispielhaft: selbst entwickeltes Schülerfestival-Backend auf einer verwalteten Plattform.

Lehrerwissen - IaaS: Der Anbieter stellt grundlegende virtualisierte Infrastruktur bereit, z. B. virtuelle Maschinen, Speicher und Netzwerke. Der Kunde betreibt darauf typischerweise Betriebssystem, Laufzeit und Anwendung stärker selbst. Hinter IaaS stehen reale Rechenzentren, Virtualisierung und automatisierte Bereitstellung.

Lehrerhinweis: Reale Cloudangebote sind nicht immer eindeutig einer Schublade zuzuordnen. Weitere Modelle sind z. B. Managed Databases oder Serverless/FaaS. Diese sind Vertiefung, kein Pflichtwissen.

Folie 15 - Shared Responsibility

Aussage: „Der Cloudanbieter kümmert sich um die Sicherheit.“ → **Zu einfach.**

Zuordnen: Rechenzentrum · Hardware · Netzwerk · Betriebssystem · Plattform · Anwendung · Konfiguration · Konten · Rollen · Daten.

Lehrerhinweis: *Shared Responsibility* bedeutet geteilte Verantwortung. Welche Aufgaben Anbieter und Kunde übernehmen, hängt vom Dienstmodell und Vertrag ab. Bei SaaS übernimmt der Anbieter typischerweise mehr technische Schichten als bei IaaS. Verantwortung für eigene Benutzer, Berechtigungen, Daten und Fehlkonfigurationen verschwindet jedoch nicht automatisch.

Folie 16 - Unsere Anwendung funktioniert. Ist sie damit gut?

Nach Diskussion: Funktionalität · Sicherheit · Datenschutz · Zuverlässigkeit · Wartbarkeit · verantwortungsvoller Betrieb.

Lehrerhinweis: Funktionierende Software kann trotzdem unsicher, unzuverlässig oder datenschutzwidrig sein. Diese Folie leitet vom „Bauen“ zum verantwortlichen Betrieb über.

Folie 17 - IT-Security und CIA

Confidentiality/Vertraulichkeit · Integrity/Integrität · Availability/Verfügbarkeit.

Beispiele zeilenweise einblenden: Fremde lesen Teilnehmerdaten · Workshopwahl wird manipuliert
· Anmeldung fällt aus.

Lehrerhinweis: Die CIA-Triade ist ein grundlegendes Modell der Informationssicherheit. Ein Vorfall kann mehrere Ziele gleichzeitig betreffen. „Security“ umfasst Technik, Menschen, Prozesse und Organisation.

Folie 18 - Angriffsfläche

Mensch ↔ Browser ↔ Netzwerk ↔ Frontend ↔ Backend/API ↔ Datenhaltung ↔ Infrastruktur.

Lehrerhinweis: *Angriffsfläche* bezeichnet die Gesamtheit möglicher Ansatzpunkte, über die ein System beeinträchtigt werden könnte. Dazu zählen nicht nur Softwarefehler, sondern auch Konten, Konfigurationen, Schnittstellen, Abhängigkeiten und menschliche Prozesse. Keine realen Fremdsysteme testen.

Folie 19 - White Hat, Black Hat, Grey Hat

White Hat: autorisiert und im vereinbarten Rahmen.

Black Hat: nicht autorisiert bzw. schädlich.

Grey Hat: populärer Zwischenbegriff, ggf. ohne ausreichende Autorisierung.

Lehrerhinweis: Die Farbbegriffe sind vereinfachte populäre Kategorien. Entscheidend sind Autorisierung, Handlung und Kontext. „Gute Absicht“ legitimiert keinen Zugriff auf fremde Systeme.

Folie 20 - Penetration Testing

Leitfrage: Darf man eine Anwendung absichtlich angreifen, um sie sicherer zu machen? → Ja, bei eindeutig autorisiertem Auftrag und Scope.

Black Box · Grey Box · White Box.

Lehrerhinweis: Ein Penetrationstest ist ein geplanter, autorisierter Sicherheitstest mit definiertem Umfang (*Scope*), Regeln, Zeitraum und Dokumentation. Black Box = wenig internes Wissen; White Box = umfangreiche Informationen/Quellcode; Grey Box = dazwischen. Schwerpunkt im Unterricht ist das Prinzip professioneller Prüfung, nicht die Anleitung zum Angriff fremder Systeme.

Folie 21 - Security by Design

Planung → Entwicklung → Test → Deployment → Betrieb/Monitoring → Updates → Verbesserung.

Lehrerhinweis: *Security by Design* bedeutet, Sicherheit bereits bei Anforderungen und Architektur mitzudenken. Beispiele: geringste notwendige Rechte, sichere Voreinstellungen,

Eingabeprüfung, Patch-/Updatekonzept, Logging, Backup und Wiederherstellung. *Monitoring* ist die laufende Beobachtung eines Systems. *Logging* ist die Aufzeichnung relevanter Ereignisse. Logs können selbst sensible/personenbezogene Daten enthalten und müssen geschützt werden.

Folie 22 - Authentifizierung und Autorisierung

Wer bist du? → Authentifizierung.

Was darfst du? → Autorisierung.

Lehrerhinweis: Authentifizierung prüft eine behauptete Identität, z. B. durch Passwort plus zweiten Faktor. Autorisierung entscheidet anschließend über erlaubte Aktionen/Ressourcen. Das Prinzip der geringsten Rechte (*Least Privilege*) fordert nur die tatsächlich notwendigen Berechtigungen.

Folie 23 - Kontoschutz und MFA

Einzigartige Passwörter · Passwortmanager · MFA · sichere Wiederherstellung · verdächtige Anmeldungen erkennen.

Lehrerhinweis: MFA = *Multi-Factor Authentication/Mehrfaktor-Authentisierung*: mindestens zwei unterschiedliche Faktoren, z. B. Wissen (Passwort), Besitz (Gerät/Token), biometrisches Merkmal. Keine Pauschalregel „Sonderzeichen = sicher“. Länge, Einzigartigkeit, sichere Speicherung und MFA sind wichtiger als formale Zeichenvorgaben allein.

Folie 24 - Social Engineering

Definition für Schüler: Social Engineering ist die gezielte Beeinflussung von Menschen, damit sie Informationen preisgeben oder sicherheitskritische Handlungen ausführen.

Beispiel: angeblicher IT-Support verlangt dringend Passwort oder MFA-Bestätigung.

Lehrerhinweis: Social Engineering nutzt Vertrauen, Autorität, Hilfsbereitschaft, Angst oder Zeitdruck. IT-Sicherheit betrifft deshalb nicht nur technische Schutzmaßnahmen. Identitäten und ungewöhnliche Forderungen sollten über einen unabhängigen Kommunikationsweg überprüft werden.

Folie 25 - Phishing

Definition für Schüler: Phishing ist eine Form des Social Engineering, bei der vertrauenswürdige Kommunikation vorgetäuscht wird, um Daten oder Handlungen zu erlangen.

Beispiel: „Dein Schulcloud-Konto wird heute gesperrt. Melde dich sofort über diesen Link an.“

Prüfen: Kontext · Zeitdruck · Absender/Identität · tatsächliches Linkziel · unabhängiger Rückkanal.

Lehrerhinweis: Phishing ist nicht auf schlecht geschriebene E-Mails und nicht nur auf Passwortdiebstahl beschränkt. Es kann über E-Mail, SMS, Messenger oder soziale Netzwerke erfolgen und z. B. auf Zugangsdaten, MFA-Bestätigungen, Zahlungen oder das Öffnen schädlicher Inhalte zielen. *Spear Phishing* bezeichnet stärker zielgerichtete Varianten und ist optionales Lehrerwissen.

Folie 26 - Backup und Wiederherstellung

Leitfragen: Was wird gesichert? Wo? Wann? Durch wen? Wie lange? Wie wird die Wiederherstellung getestet?

Unterscheiden:

Konzept	Zweck
Synchronisation	Datenstände abgleichen
Redundanz	Ausfall einzelner Komponenten abfangen
Backup	früheren Datenstand wiederherstellen
Archiv	Daten langfristig aufbewahren

Lehrerhinweis: Cloud-Synchronisation ist nicht automatisch Backup. Ein Backup sollte vom Produktivsystem angemessen getrennt sein und Wiederherstellung (*Restore*) muss getestet werden. Ein nicht wiederherstellbares Backup erfüllt seinen Zweck nicht.

Lehrervertiefung: 3-2-1 ist eine verbreitete Faustregel: drei Datenkopien, zwei unterschiedliche Speicherarten/Medien, eine Kopie getrennt/offsite. RPO (*Recovery Point Objective*) beschreibt vereinfacht, wie viel Datenverlust zeitlich akzeptabel ist; RTO (*Recovery Time Objective*), wie lange die Wiederherstellung dauern darf.

Folie 27 - Backup ist selbst ein Security- und Datenschutzthema

Fragen: Wer darf Backupdaten lesen? Wo liegen sie? Sind sie verschlüsselt? Wie lange werden sie aufbewahrt? Wie werden sie gelöscht?

CIA-Bezug: Verfügbarkeit durch Wiederherstellung · Integrität der Sicherung · Vertraulichkeit der Backupdaten.

Lehrerhinweis: Backups können vollständige Kopien sensibler Daten enthalten und sind daher selbst schützenswerte Informationsbestände. Mehr Sicherungen erhöhen nicht automatisch die Sicherheit, wenn Zugriff, Aufbewahrung und Löschung ungeklärt sind.

Folie 28 - Wofür Verschlüsselung?

Situationen: Browser↔Server · Datenbank/Datenträger · Backup · verlorenes Notebook · vertrauliche Nachricht.

Data in Transit: Daten während der Übertragung.

Data at Rest: gespeicherte Daten.

Lehrerhinweis: Verschlüsselung dient vor allem dem Schutz der Vertraulichkeit gegen unberechtigtes Lesen. Der konkrete Schutz hängt vom Bedrohungsmodell ab. *Data in Use* bezeichnet Daten während der Verarbeitung; klassische Verschlüsselung kann dort nicht alle Risiken lösen.

Folie 29 - HTTPS/TLS: Schutz der Kommunikation

Browser ⇌ **verschlüsselte TLS-Verbindung** ⇌ Webserver.

Lehrerhinweis: TLS (*Transport Layer Security*) schützt Daten auf dem Transportweg gegen einfaches Mitlesen und Manipulation und ermöglicht die Authentisierung der Gegenstelle über

Zertifikate. HTTPS = HTTP über TLS. Eine HTTPS-Seite kann trotzdem betrügerisch oder eine Anwendung unsicher sein.

Folie 30 - Verschlüsselung gespeicherter Daten

Beispiele: Geräte-/Volume-Verschlüsselung · verschlüsselte Backups · ggf. anwendungsseitige Verschlüsselung.

Lehrerhinweis: Datenträgerverschlüsselung schützt z. B. bei Verlust eines ausgeschalteten Geräts. Ist das System bereits entsperrt und die Anwendung kompromittiert, kann sie die entschlüsselten Daten ggf. lesen. Wichtig ist Schlüsselmanagement: Wer besitzt Schlüssel, wo werden sie gesichert, was geschieht bei Verlust? Backup und Schlüssel ungeschützt am selben Ort schwächen den Schutz; verlorene Schlüssel können Wiederherstellung unmöglich machen.

Folie 31 - Symmetrisch und asymmetrisch

Symmetrisch: gemeinsamer geheimer Schlüssel; effizient für große Datenmengen.

Asymmetrisch: zusammengehöriger öffentlicher und privater Schlüssel; unterstützt u. a. Authentisierung und Schlüsselaushandlung.

Lehrerhinweis: Reale Protokolle wie TLS kombinieren Verfahren. Nicht behaupten, die gesamte HTTPS-Kommunikation werde einfach asymmetrisch verschlüsselt. Public-Key-Verfahren helfen u. a. bei Authentisierung/Schlüsselaushandlung; die eigentliche Datenübertragung nutzt typischerweise effiziente symmetrische Verfahren.

Folie 32 - Verschlüsselung, Hashing, Signatur

Verschlüsselung: Inhalt vor unberechtigtem Lesen schützen.

Hash: Einweg-Fingerabdruck eines Datenwerts.

Digitale Signatur: Integrität und Herkunft/Authentizität eines signierten Inhalts prüfbar machen.

Lehrerhinweis: Hashing ist keine Verschlüsselung und wird nicht „entschlüsselt“. Passwörter sollten serverseitig nicht einfach reversibel verschlüsselt gespeichert werden, sondern mit geeigneten Passwort-Hashing-Verfahren samt Salt verarbeitet werden. Kryptografische Details sind Lehrervertiefung; Schüler sollen die unterschiedlichen Zwecke verstehen.

Folie 33 - IT-Sicherheit ≠ Datenschutz

IT-Sicherheit: Systeme und Informationen gegen Risiken schützen.

Datenschutz: rechtmäßiger und angemessener Umgang mit personenbezogenen Daten.

Lehrerhinweis: Eine technisch hervorragend verschlüsselte Datenbank kann trotzdem personenbezogene Daten enthalten, die nicht erforderlich oder nicht rechtmäßig erhoben wurden. Umgekehrt benötigt Datenschutz angemessene technische und organisatorische Schutzmaßnahmen. Die Bereiche überschneiden sich, sind aber nicht identisch.

Folie 34 - DSGVO

Schülerperspektive: Welche personenbezogenen Daten brauchen wir für das Schülerfestival wirklich? Wer darf sie nutzen? Wie lange benötigen wir sie?

Lehrerhinweis: DSGVO = Datenschutz-Grundverordnung der EU. Für den Unterricht stehen Grundideen im Vordergrund: Zweckbindung, Datenminimierung, Transparenz, angemessener Schutz und Rechte betroffener Personen. Keine Rechtsberatung und keine Paragraphenprüfung erforderlich.

Folie 35 - NIS2: Cybersicherheit als Organisationsaufgabe

Für Schüler: Für bestimmte Unternehmen und Einrichtungen gibt es gesetzliche Anforderungen, Cybersicherheitsrisiken systematisch zu beherrschen. Sicherheit ist dort nicht nur freiwillige Empfehlung.

Lehrerwissen: NIS steht für *Network and Information Systems*. NIS2 ist die zweite EU-Richtlinie zu Cybersicherheit von Netz- und Informationssystemen. Sie betrifft nicht pauschal jedes Unternehmen und jede Website. Welche Organisationen konkret erfasst sind, hängt u. a. von Sektor, Größe und der geltenden nationalen Umsetzung ab.

Praxisbezug: Risikomanagement · Vorfallbehandlung · Business Continuity/Backup · Lieferkettensicherheit · Schwachstellenmanagement · Cyberhygiene · Kryptografie · Zugriffsschutz/MFA · ggf. Meldepflichten.

Lehrerhinweis: NIS2 zeigt, dass Security auch Management-, Prozess- und Organisationsaufgabe ist. DSGVO und NIS2 nicht vermischen: DSGVO fokussiert personenbezogene Daten und deren Verarbeitung; NIS2 Cybersicherheit und Resilienz bestimmter Organisationen. Ein Vorfall kann beide Bereiche berühren.

Aktualität: Konkrete Pflichten, Schwellenwerte und betroffene Einrichtungen vor vertiefender Behandlung anhand aktueller offizieller Quellen prüfen. Das Unterrichtsmaterial vermittelt Grundprinzipien und ersetzt keine Rechtsberatung.

Folie 36 - KI auf Angreifer- und Verteidigerseite

Angriff: überzeugenderes Phishing · Informationsauswertung · Social Engineering/Deepfakes · Automatisierung.

Verteidigung: Anomalieerkennung · Loganalyse · Codeanalyse · Unterstützung von Security-Teams.

Lehrerhinweis: KI ist weder automatisch Angriffs- noch Schutztechnik. Sie kann Fähigkeiten auf beiden Seiten verstärken. *Deepfake* bezeichnet künstlich erzeugte/manipulierte Medien, die reale Personen oder Ereignisse glaubhaft vortäuschen können. *Anomalieerkennung* sucht auffällige Abweichungen von erwarteten Mustern. KI-Ergebnisse können falsch sein und müssen überprüft werden.

Folie 37 - KI-generierter Code: niemals blind übernehmen

Kernaussage auf der Folie:

KI-generierter Code muss immer geprüft werden und darf niemals blind übernommen werden.

Mögliche Probleme: fachliche/logische Fehler · Sicherheitslücken · veraltete/ungeeignete Abhängigkeiten · Datenschutzprobleme · Lizenz-/Herkunftsfragen · schlechte Wartbarkeit.

Prüfschema: **Funktion → Verständlichkeit → Sicherheit → Datenschutz → Abhängigkeiten → Tests.**

Lehrerhinweis: „Der Code läuft“ ist kein Qualitäts- oder Sicherheitsnachweis. Wer Code übernimmt, muss ihn verstehen, erklären, testen, warten und verantworten können. Besonders kritisch sind Login, Rechteprüfung, Kryptografie, Eingabevalidierung und Datenbankzugriffe. KI kann Code vorschlagen; die Verantwortung für den eingesetzten Code bleibt beim Menschen bzw. betreibenden Team.

Folie 38 - Abschlussfall Schülerfestival

Architektur: Angular-Frontend ⇌ API ⇌ Backend ⇌ Datenbank; Betrieb in Cloudumgebung; optional WebSocket für Live-Änderungen.

Daten: Name · Klasse · E-Mail · Workshopwahl.

Auftrag: Prüft das System als Architektur-, Datenschutz- und Security-Team.

Fragen: Welche Daten brauchen wir? Wer darf was? Welche Schutzziele? Wie sichern/wiederherstellen? Welche Daten verschlüsseln wir wo? Wer trägt welche Cloud-Verantwortung? Wo sind Live-Verbindungen sinnvoll? Wo kann KI helfen und was muss geprüft werden?

Lehrerhinweis: Es gibt nicht nur eine richtige Architektur. Bewertet werden begründete Entscheidungen und das Erkennen von Abhängigkeiten/Zielkonflikten.

Folie 39 - Sicherung

Eine gute Webanwendung muss mehr als funktionieren.

Einzelne einblenden: verständlich aufgebaut · zuverlässig · angemessen geschützt · datenschutzbewusst · sicher betrieben/aktualisiert · verantwortungsvoll weiterentwickelt.

Lehrerhinweis: Abschluss bewusst auf Systemverantwortung richten. Die Schüler sollen Architektur, Daten, Sicherheit und Betrieb nicht mehr als getrennte Themen betrachten.

Folie 40 - Exit-Ticket

1. Warum ist eine Webanwendung nicht nur das Frontend?
2. Warum beschreibt Client/Server nicht die Richtung jeder einzelnen Nachricht?
3. Nenne drei Stellen, an denen Sicherheitsentscheidungen getroffen werden.
4. Erkläre den Unterschied zwischen Backup und Synchronisation.
5. Nenne je ein Beispiel für Data in Transit und Data at Rest.
6. Warum darf KI-generierter Code nicht blind übernommen werden?

Lehrerhinweis: Antworten können als Diagnose für die nächste Stunde genutzt werden. Nicht alle sechs Fragen müssen gleichzeitig bearbeitet werden.

Konventionen für Präsentation und Lehrerhinweise - Klasse 10 Webbasierte Anwendungen

Diese Regeln gelten für die Präsentation 01_05_Webbasierte_Anwendungen und sollen bei späteren Überarbeitungen konsistent angewendet werden.

Fachbegriffe und Abkürzungen

- Beim **ersten Auftreten** wird der Begriff ausgeschrieben und die Abkürzung anschließend in Klammern angegeben, z. B. **Server-Sent Events (SSE)**, **Hypertext Transfer Protocol (HTTP)**, **Application Programming Interface (API)** oder **Single Page Application (SPA)**.
- Danach darf die Abkürzung allein verwendet werden.
- Ein Begriff darf auf der Schülerfolie nicht vorausgesetzt werden, wenn er für das Verständnis der Folie notwendig ist.

Lehrerhinweise

- Lehrerhinweise sollen keine berufspraktische Erfahrung mit Webentwicklung, Cloud oder IT-Security voraussetzen.
- **Jeder neu erklärte Fachbegriff erhält einen eigenen Absatz.**
- Der Begriff steht möglichst am Absatzanfang und wird hervorgehoben; danach folgen verständliche Erklärung und bei Bedarf ein Beispiel.
- Fachliche Vereinfachungen für Schülerinnen und Schüler werden im Lehrerhinweis präzisiert.
- Abkürzungen werden auch im Lehrerhinweis bei ihrer ersten Verwendung ausgeschrieben.

3-Tier und Schichten

Ein Tier bezeichnet eine Architektur- bzw. Bereitstellungsebene. Drei Tiers bedeuten nicht zwingend drei physische Rechner. Mehrere Tiers können auf einem System laufen; ein Tier kann auf mehrere Systeme verteilt sein.

Presentation Tier: Benutzeroberfläche sowie Ein- und Ausgabe.

Application Tier: Anwendungs- bzw. Geschäftslogik (Business Logic).

Data Tier: Datenhaltung und Datenzugriff, beispielsweise über eine Datenbank.

Layer / Schicht: Im Deutschen wird häufig von einer Drei-Schichten-Architektur gesprochen. Fachlich können Layer und Tier unterschieden werden: Layer beschreibt eher die logische Struktur, Tier eher die Bereitstellung. Im Schulkontext werden die Begriffe häufig vereinfachend ähnlich verwendet.

Client/Server, Frontend/Backend und Rendering

„Frontend = Client“ und „Backend = Server“ ist nur ein grobes Einstiegsmodell.

Serverseitiges Rendering: Der Server erzeugt die anzuzeigende HTML-Seite ganz oder teilweise. Beispiele für Technologien sind PHP, JavaServer Pages (JSP), JavaServer Faces (JSF) oder Oracle Application Development Framework (Oracle ADF). Diese Technologien sind Lehrerwissen und kein Lernziel.

Single Page Application (SPA): Bei einer SPA, beispielsweise mit Angular, wird ein größerer Teil der Benutzeroberfläche durch JavaScript im Browser erzeugt und verändert. Das Backend stellt häufig Daten und Funktionen über Schnittstellen bereit.

Abgrenzung: Client/Server beschreibt Rollen in einer Kommunikation. Frontend/Backend beschreibt Bereiche bzw. Verantwortlichkeiten einer Anwendung. Die Begriffspaare sind nicht synonym.

Kommunikation

Die Kommunikationsformen werden schrittweise eingeführt: **HTTP Request/Response → Polling → Server-Sent Events (SSE) → WebSocket → Vergleich.**

Polling: Kein eigenes Netzwerkprotokoll, sondern ein Kommunikationsmuster. Im Web häufig wiederholte HTTP-Request-/Response-Zyklen.

Server-Sent Events (SSE): Länger bestehende HTTP-Verbindung, über die der Server Ereignisse an den Client senden kann. Für die Gegenrichtung können normale HTTP-Anfragen verwendet werden.

WebSocket: Länger bestehende bidirektionale Verbindung. Client und Server können Nachrichten senden. Ein Subscription-Modell ist Anwendungslogik und nicht automatisch Bestandteil des WebSocket-Protokolls.

Bei mehreren Backend-Instanzen wird erklärt, dass eine bestehende WebSocket-Verbindung einer Instanz zugeordnet bleibt. Bei einem Reconnect kann eine andere Instanz gewählt werden. Notwendiger Verbindungszustand soll deshalb reproduzierbar wiederhergestellt werden können. Sticky Sessions sind eine mögliche Option, aber keine notwendige WebSocket-Lösung.